

Producción de Software

Pablo Valenzuela

4 Mayo 2026

The State of the SBOM Tool Ecosystems: A Comparative Analysis of SPDX and CycloneDX

1. **RQ1:** ¿Qué casos de uso soportan las herramientas SBOM actuales?
2. **RQ2:** ¿Cómo se distribuye la salud de las herramientas SBOM de código abierto actuales?
3. **RQ3:** ¿Cuáles son las áreas de mejora en las herramientas SBOM de código abierto?
4. **RQ4:** ¿Cómo se distribuye la salud de los proyectos de GitHub que usan herramientas SBOM?

The State of the SBOM Tool Ecosystems: A Comparative Analysis of SPDX and CycloneDX

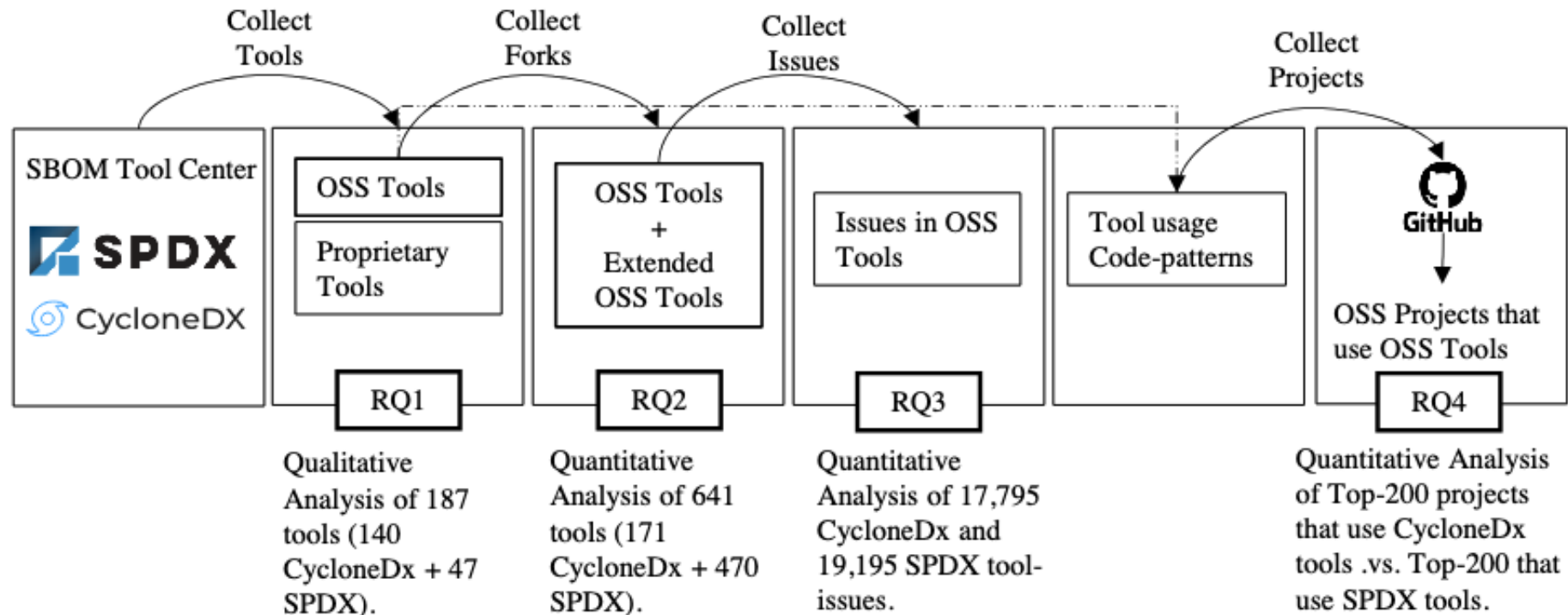


Fig. 1: Overview of our methodology and dataset.

RQ1: ¿Qué casos de uso soportan las herramientas SBOM actuales?

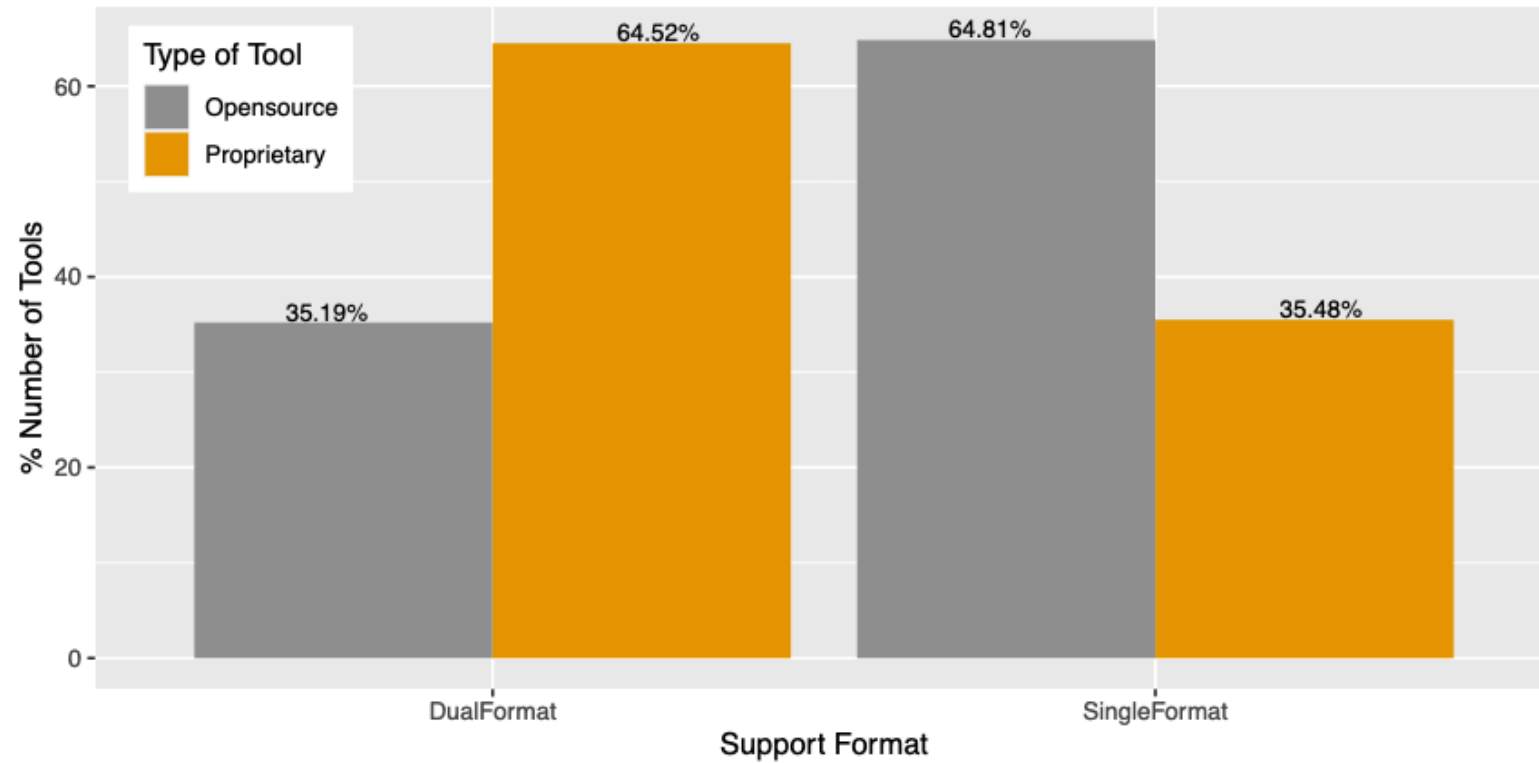


Fig. 2: Distribution of 170 manually analyzed SBOM tools across the SBOM specifications that they support. DualFormat tools support both formats, while SingleFormat tools support a single format.

RQ1: ¿Qué casos de uso soportan las herramientas SBOM actuales?

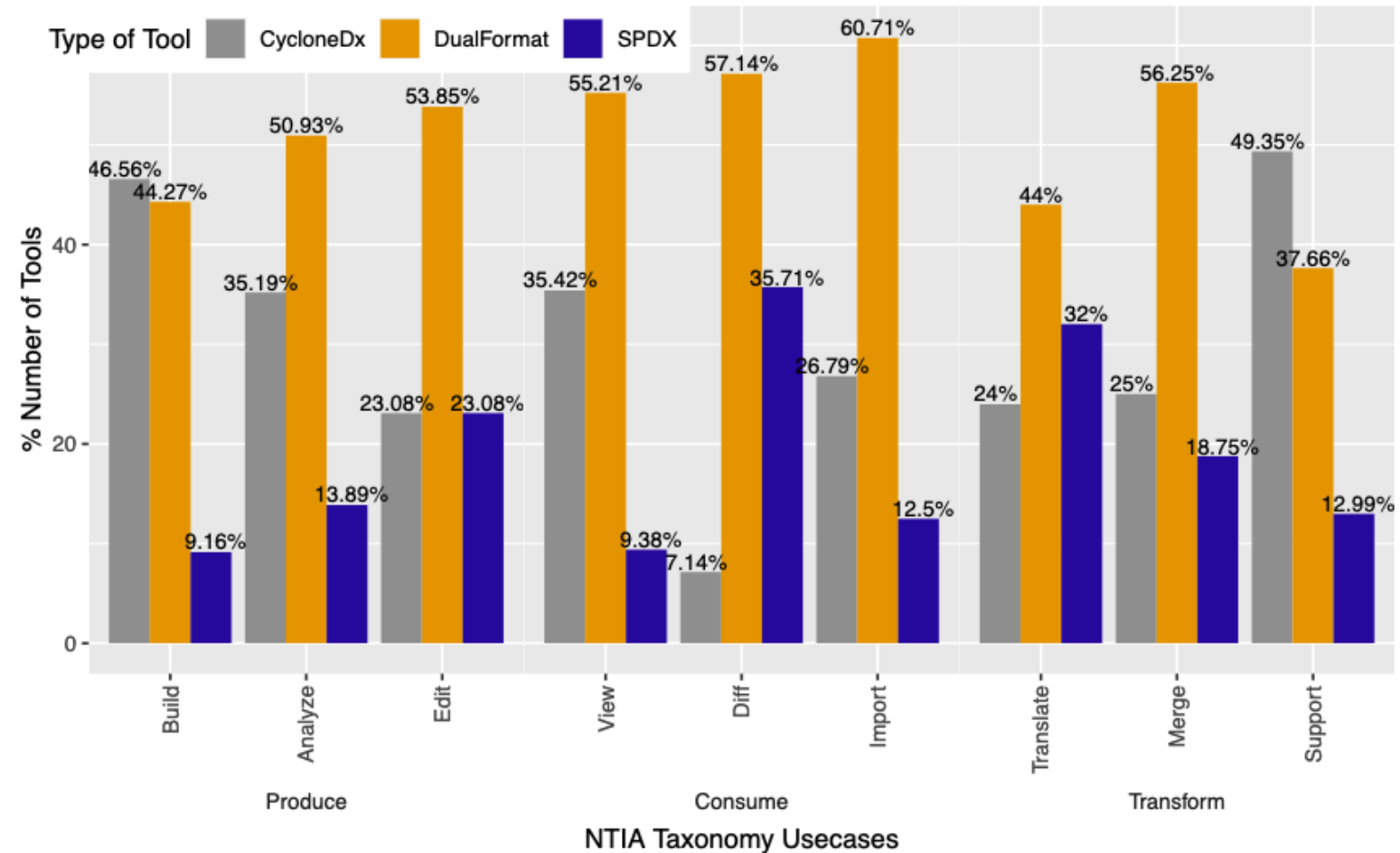


Fig. 3: Distribution of the 170 manually analyzed tools across Open-source vs. Proprietary. DualFormat tools support both formats.

RQ1: ¿Qué casos de uso soportan las herramientas SBOM actuales?

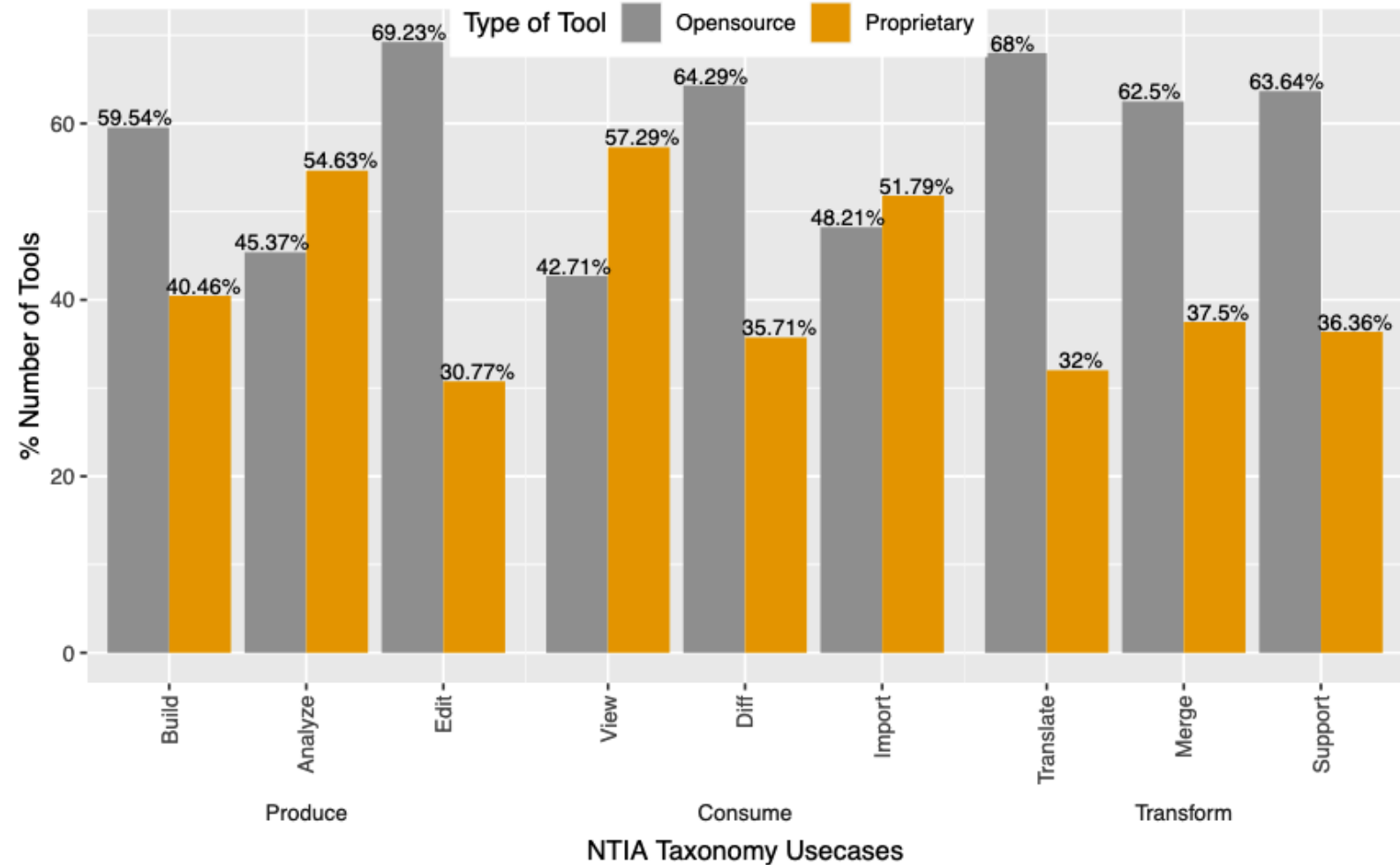


Fig. 5: Comparison of how 170 SBOM tools (both open-source and proprietary) distributed across the NTIA's use case taxonomy.

The State of the SBOM Tool Ecosystems: A Comparative Analysis of SPDX and CycloneDX

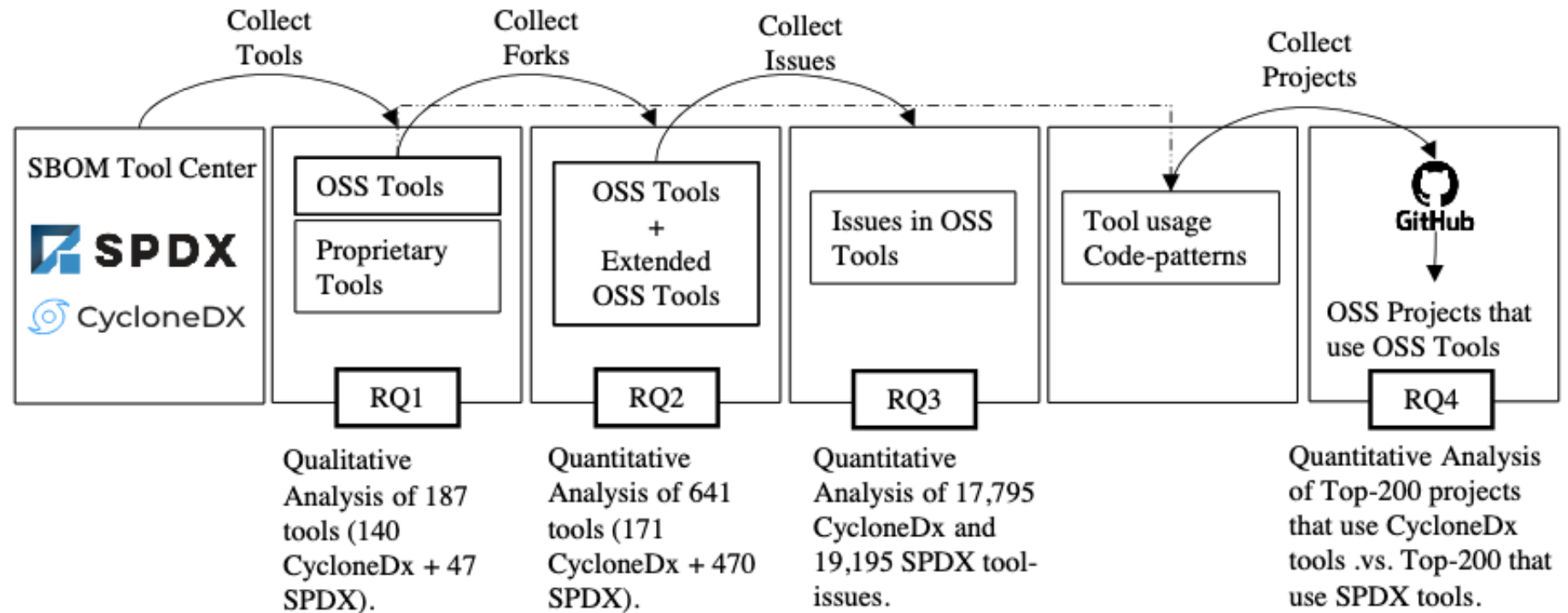


Fig. 1: Overview of our methodology and dataset.

RQ2: ¿Cómo se distribuye la salud de las herramientas SBOM de código abierto actuales?

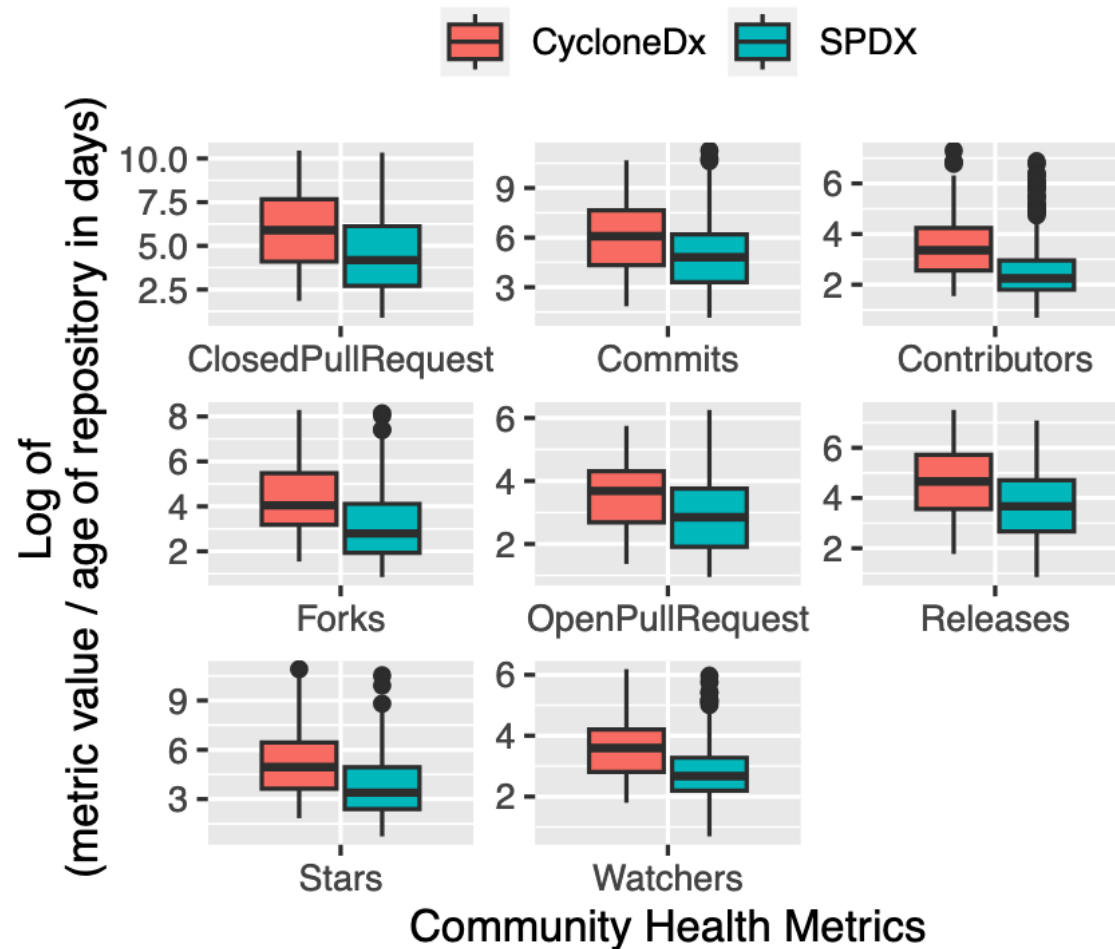


Fig. 7: Comparison of the distribution of normalized metrics (by repository age), i.e., #PRs, #Contributors, #Stars, #Watchers, #Releases, #Forks representing the community-health metrics of 470 SPDX and 171 CycloneDX tool repositories.

RQ2: ¿Cómo se distribuye la salud de las herramientas SBOM de código abierto actuales?

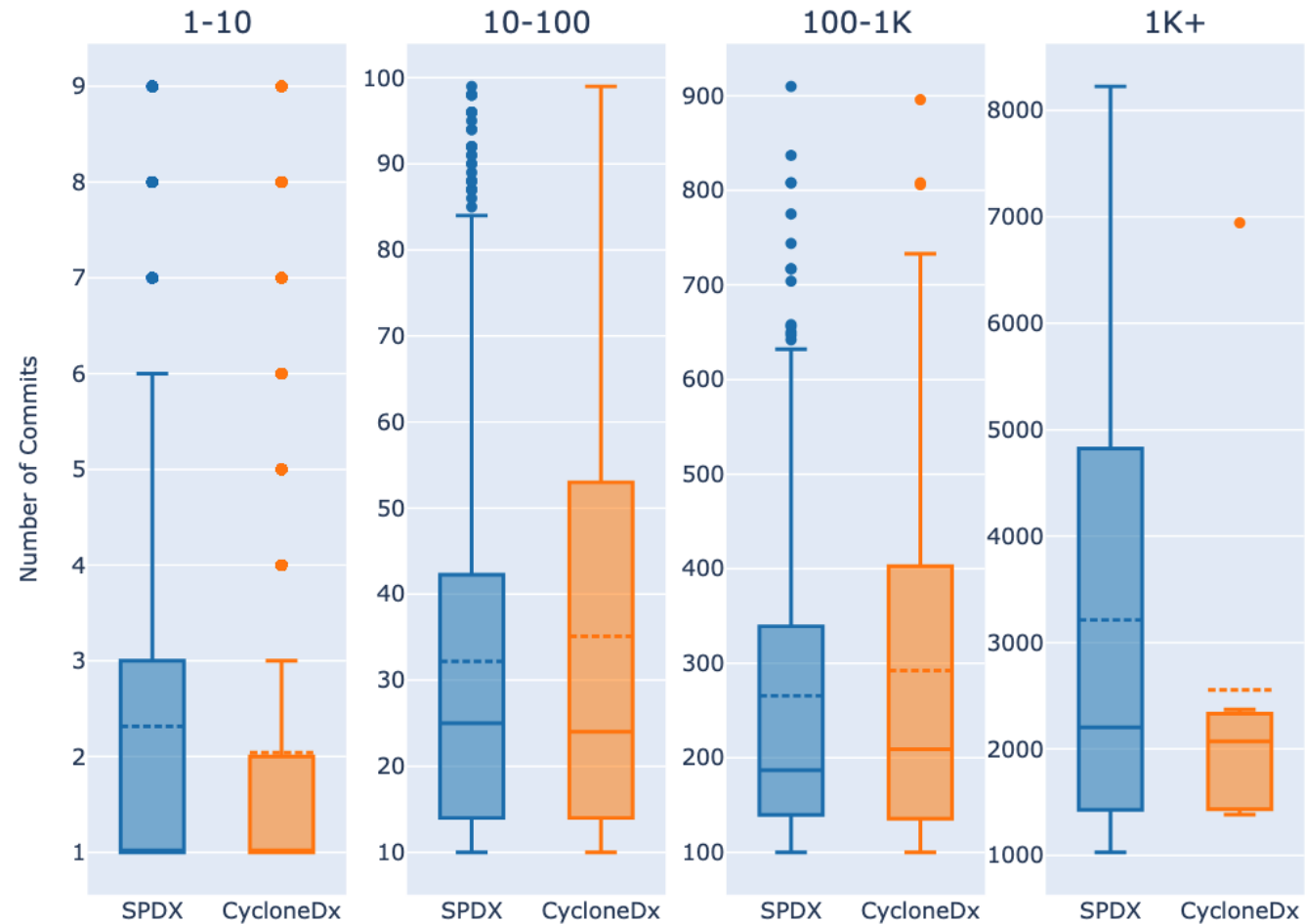


Fig. 8: Distribution of open-source contributor groups (by number of normalized commits) across 470 SPDX and 171 CycloneDX tool repositories.

The State of the SBOM Tool Ecosystems: A Comparative Analysis of SPDX and CycloneDX

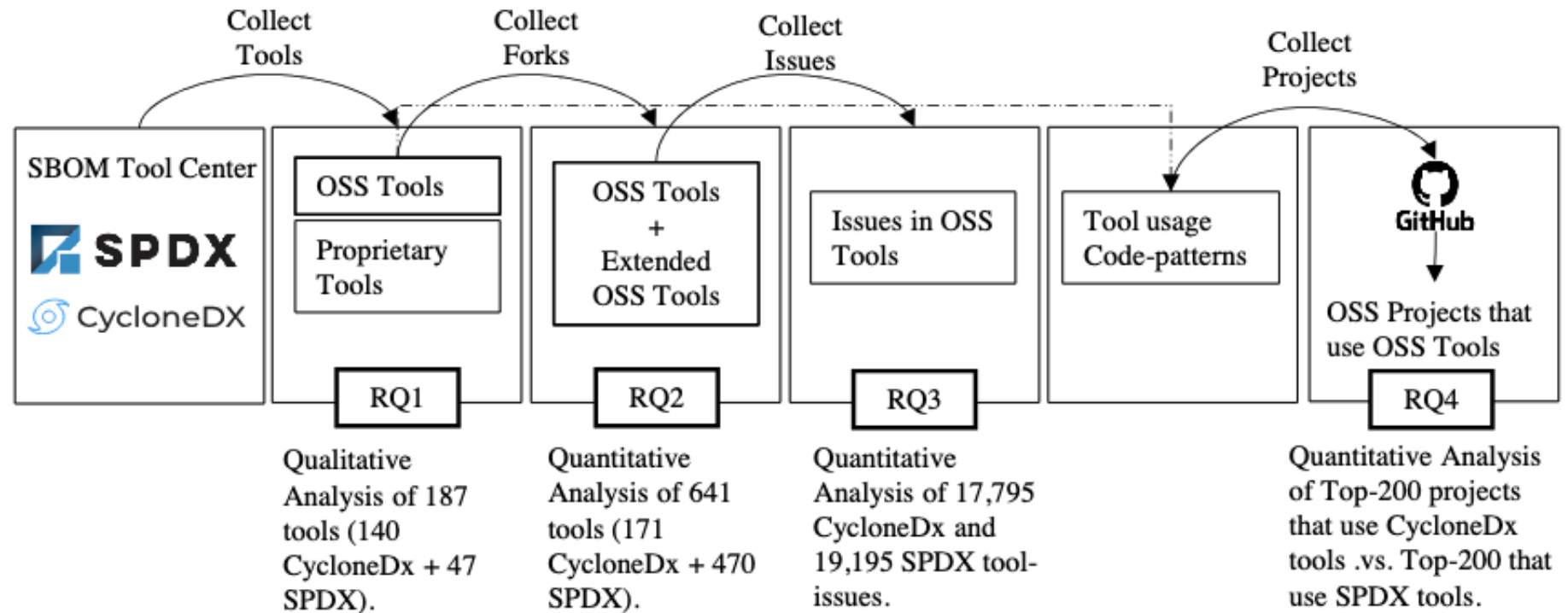


Fig. 1: Overview of our methodology and dataset.

RQ3: ¿Cuáles son las áreas de mejora en las herramientas SBOM de código abierto?

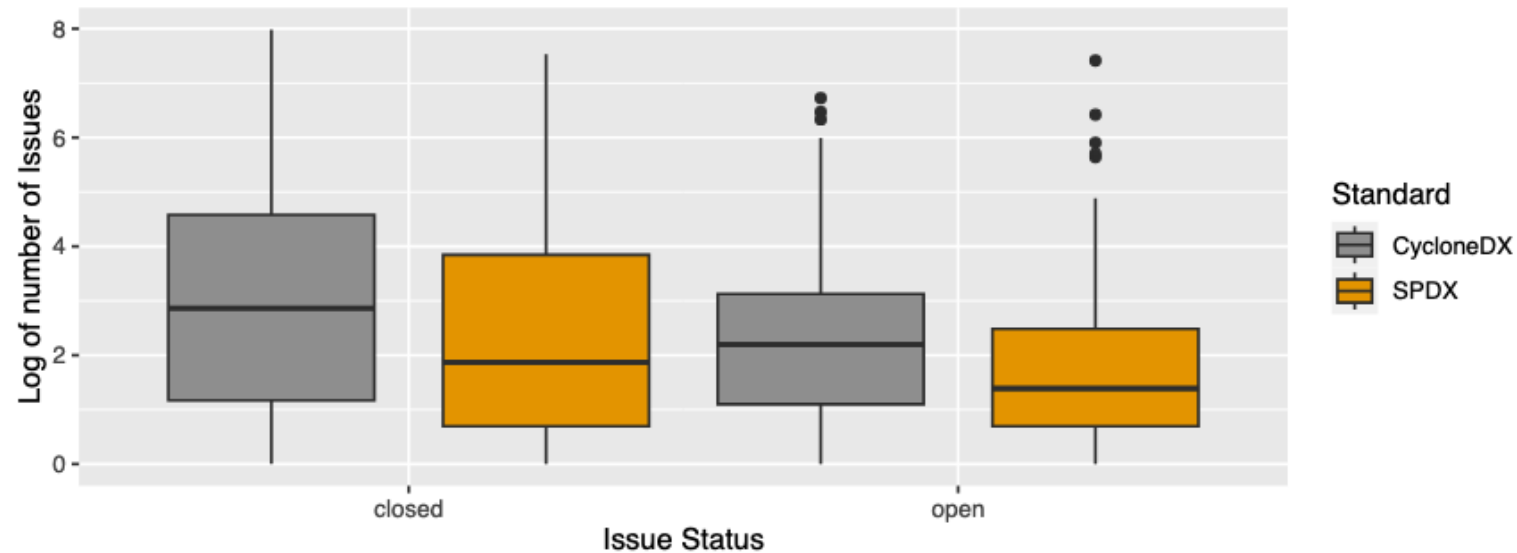


Fig. 9: Representation of 17,093 issue reports in 90 CycloneDX tool repositories and 16,747 issue reports in 171 SPDX tool repositories.

RQ3: ¿Cuáles son las áreas de mejora en las herramientas SBOM de código abierto?

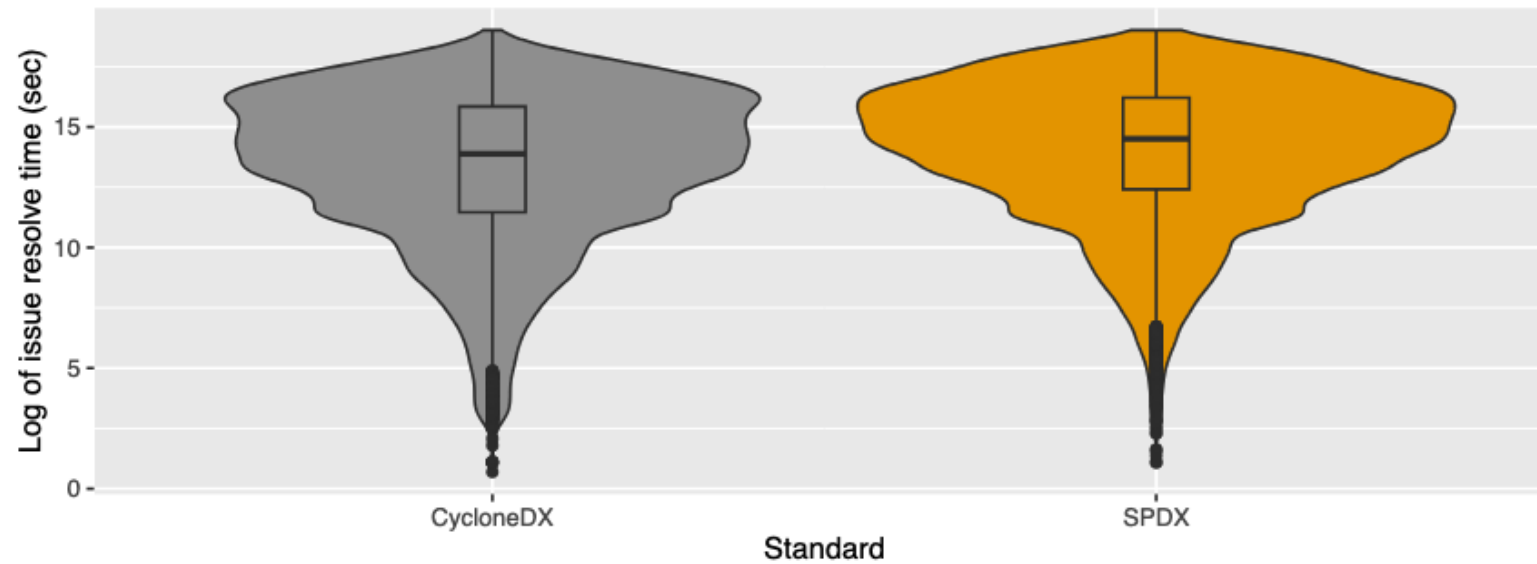
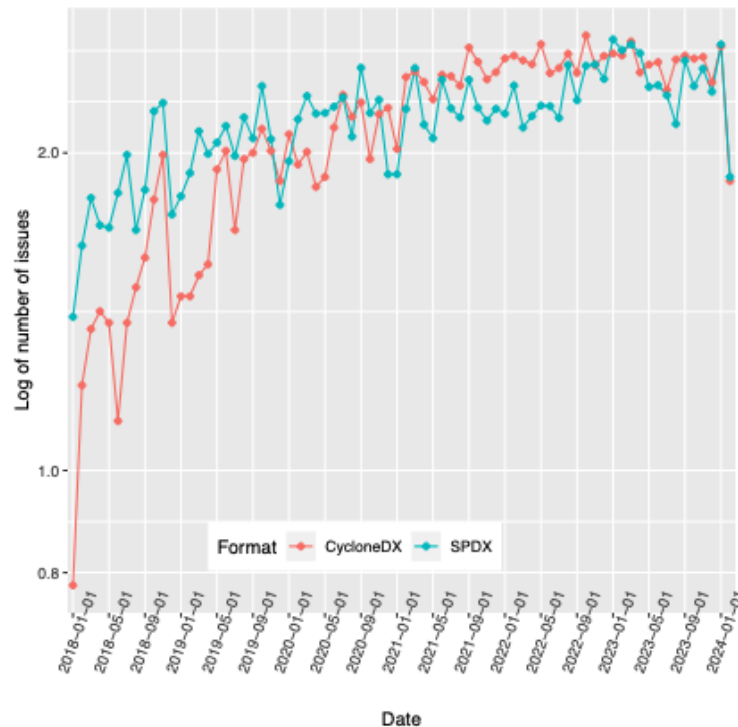
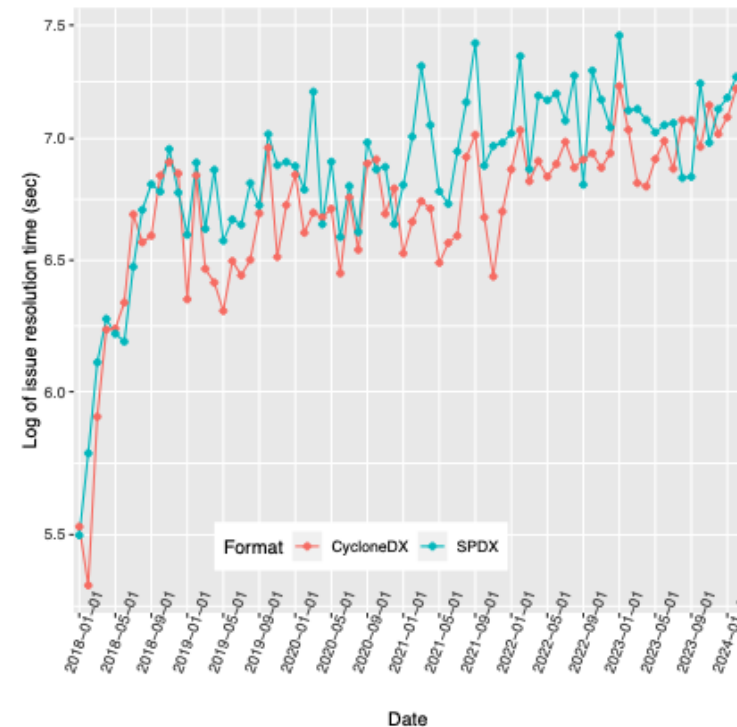


Fig. 10: Resolution time of 13,281 closed issue reports in 90 CycloneDX tool repositories and 13,352 closed issue reports in 191 SPDX tool repositories.

RQ3: ¿Cuáles son las áreas de mejora en las herramientas SBOM de código abierto?



(a) Prevalence of issue reports.



(b) Resolution time of issue reports.

Fig. 11: Trend of prevalence and resolution time of issue reports from 2018 to 2023.

RQ3: ¿Cuáles son las áreas de mejora en las herramientas SBOM de código abierto?

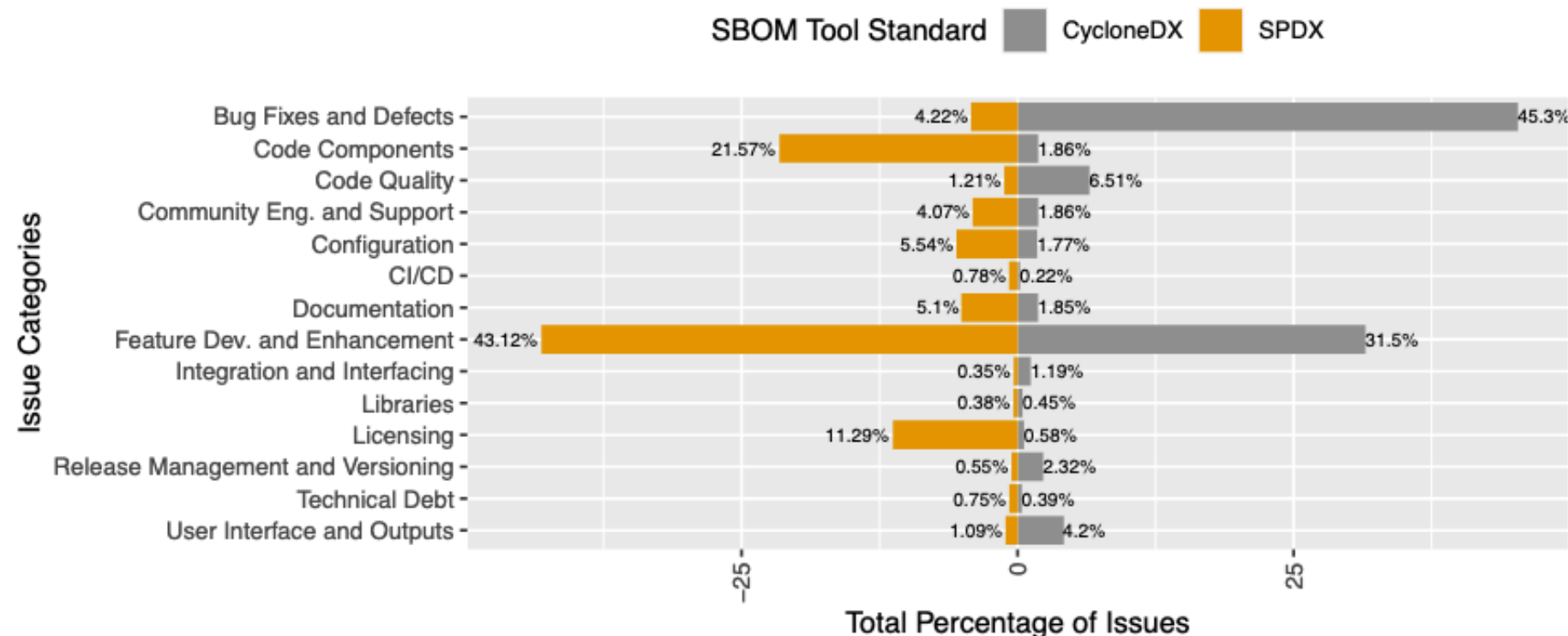


Fig. 12: The distribution of Github issue reports by their category across SPDX and CycloneDX SBOM tools.

RQ3: ¿Cuáles son las áreas de mejora en las herramientas SBOM de código abierto?

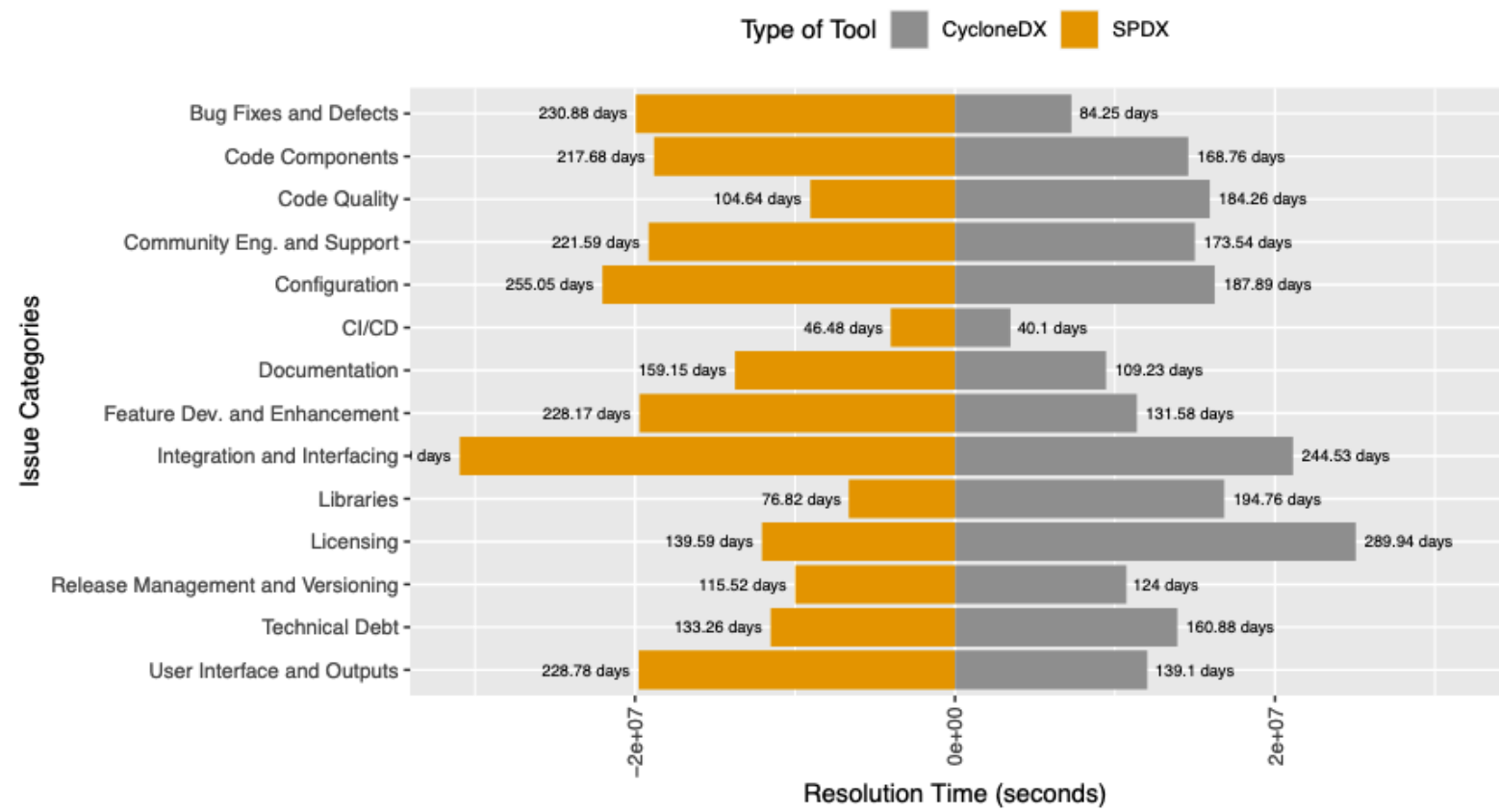


Fig. 13: Distribution of resolution time (in seconds) of issue categories of SPDX and CycloneDX tools.

RQ3: ¿Cuáles son las áreas de mejora en las herramientas SBOM de código abierto?

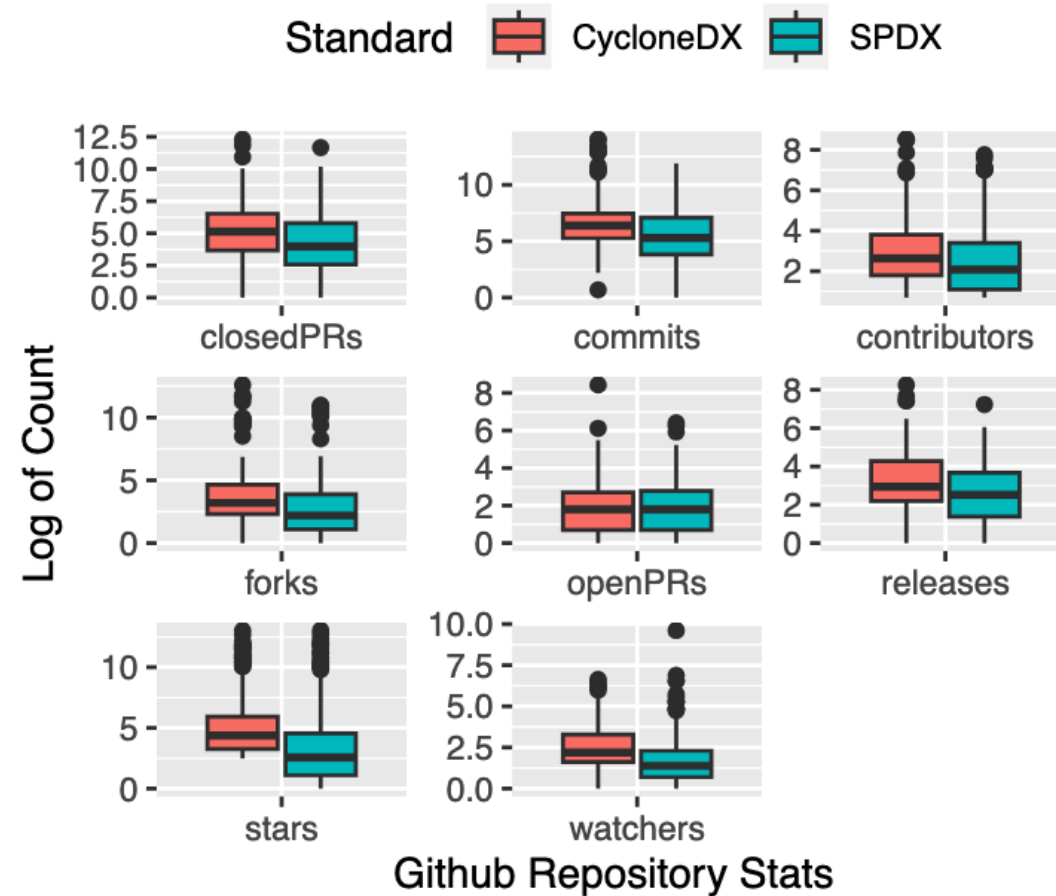


Fig. 14: Community health metrics of Top-250 projects that use SPDX tools vs. Top-250 projects that use CycloneDX tools. Log of count is normalized by the age of repository in days.

The State of the SBOM Tool Ecosystems: A Comparative Analysis of SPDX and CycloneDX

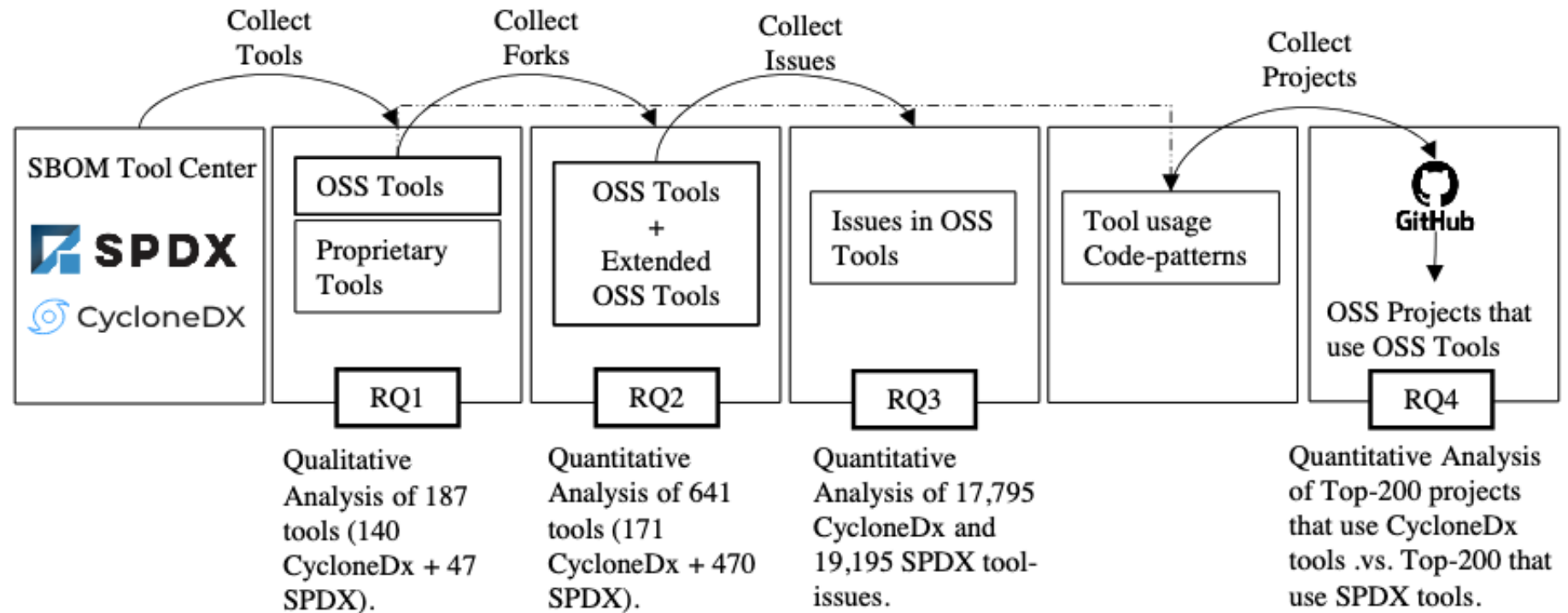
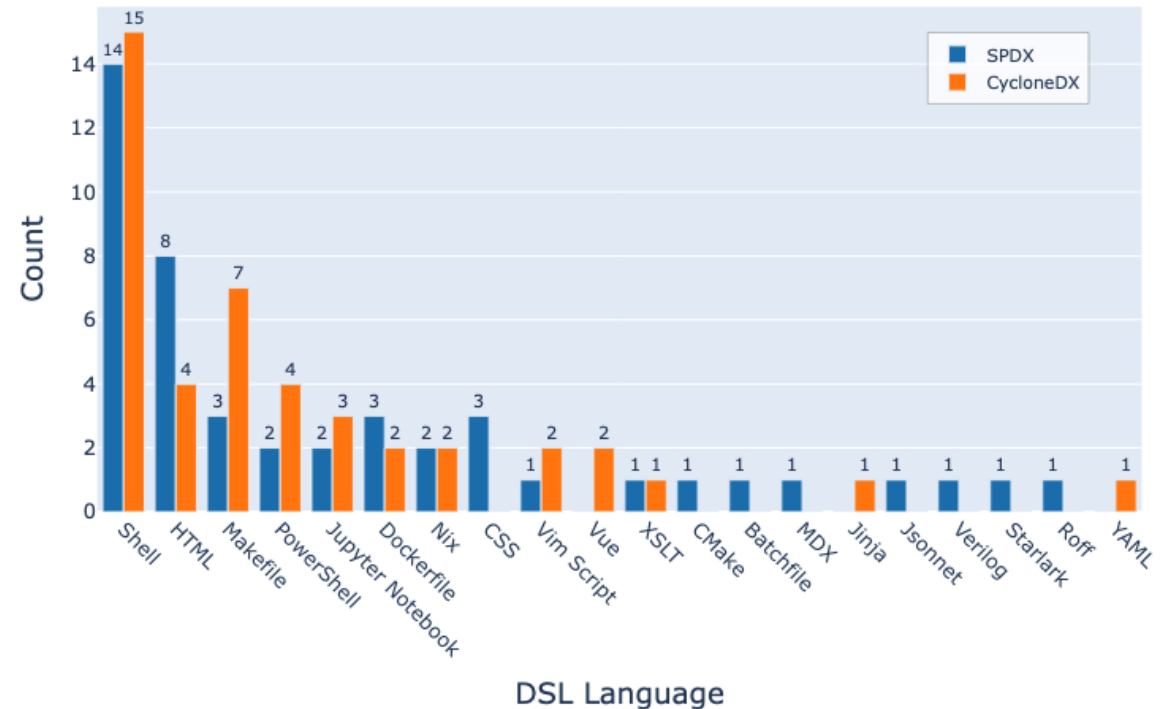
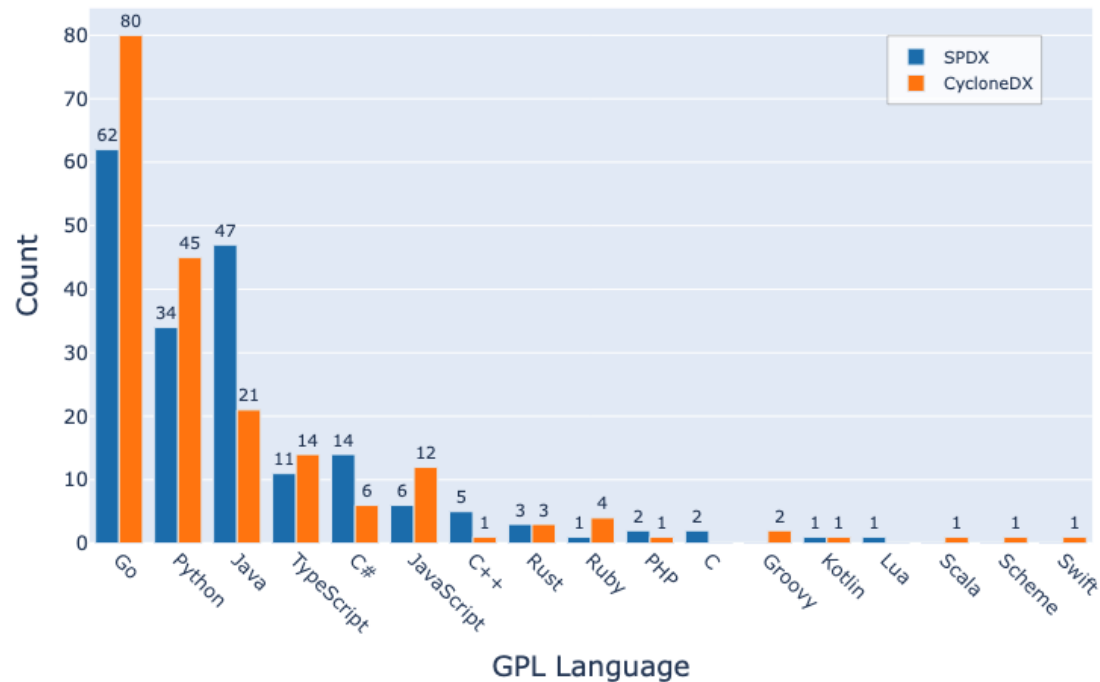


Fig. 1: Overview of our methodology and dataset.

RQ4: ¿Cómo se distribuye la salud de los proyectos de GitHub que usan herramientas SBOM?



Los proyectos que adoptan herramientas SBOM no son homogéneos, ya que su elección se asocia a distintos tipos de proyectos, donde CycloneDX aparece más en entornos modernos y activos, mientras que SPDX se vincula más a contextos tradicionales y orientados a cumplimiento.

Implicancias

- Las herramientas SBOM open-source deben mejorar sus capacidades de análisis y visualización para cerrar la brecha con las soluciones propietarias.

Implicancias

- Las herramientas SBOM open-source deben mejorar sus capacidades de análisis y visualización para cerrar la brecha con las soluciones propietarias.
- La elección de herramientas SBOM debe considerar el ecosistema completo (integración, actividad y casos de uso), no solo el formato.

Implicancias

- Las herramientas SBOM open-source deben mejorar sus capacidades de análisis y visualización para cerrar la brecha con las soluciones propietarias.
- La elección de herramientas SBOM debe considerar el ecosistema completo (integración, actividad y casos de uso), no solo el formato.
- La elección de herramientas SBOM debe considerar el ecosistema completo (integración, actividad y casos de uso), no solo el formato.

Implicancias

- Las herramientas SBOM open-source deben mejorar sus capacidades de análisis y visualización para cerrar la brecha con las soluciones propietarias.
- La elección de herramientas SBOM debe considerar el ecosistema completo (integración, actividad y casos de uso), no solo el formato.
- La elección de herramientas SBOM debe considerar el ecosistema completo (integración, actividad y casos de uso), no solo el formato.
- La elección de herramientas SBOM debe considerar el ecosistema completo (integración, actividad y casos de uso), no solo el formato.

The State of the SBOM Tool Ecosystems: A Comparative Analysis of SPDX and CycloneDX

- **La elección de una herramienta SBOM no es una decisión técnica aislada, sino una decisión sobre el ecosistema completo en el que vas a operar**
 - distintas herramientas no solo hacen cosas diferentes (RQ1),
 - sino que viven en comunidades con distintos niveles de actividad (RQ2),
 - tienen problemas distintos (RQ3),
 - y terminan siendo adoptadas por proyectos con dinámicas muy diferentes (RQ4),
- Entoces, si eliges solo por el formato o la funcionalidad, estás ignorando el factor que realmente determina el éxito en la práctica

Referencias

- Bangash, A. A., Ge, T., Zhao, Z., Singh, A., Wang, Z., & Adams, B. (2025). The State of the SBOM Tool Ecosystems: A Comparative Analysis of SPDX and CycloneDX. *arXiv preprint arXiv:2512.21781*.
- <https://github.com/SAILResearch/wip-24-ali-sbom-emse>